

49. Clickjacking Attack

Is attack me ek evil page **visitor ki taraf se** kisi "victim site" par click karwa deti hai (visitor ko pata bhi nahi chalta). Twitter, Facebook, PayPal jaisi sites is tarah hack hui (ab fix hain).

Idea

1. Visitor evil page par pahunchta hai (kisi bhi tarah).
2. Page par ek **masoom link/button** hai ("get rich now", "click here, very funny").
3. Uske upar evil page ek **transparent** `<iframe>` rakhti hai jiska `src` facebook.com jaisi victim site hai, aur iframe me "Like" button bilkul us link ke upar aata hai (`z-index` se).
4. Visitor link par click karna chahta hai, par asal me **"Like" button** click ho jaata hai.

```
html

<style>
iframe {
  width: 400px; height: 100px;
  position: absolute; top: 0; left: -20px;
  opacity: 0;          /* asal me fully transparent */
  z-index: 1;
}
</style>
<div>Click to get rich now:</div>
<iframe src="victim-site.html"></iframe>
<button>Click here!</button>
```

Agar visitor victim site par login hai ("remember me"), to Facebook par "Like" ya Twitter par "Follow" ho jaata hai.

Ye attack sirf **clicks** (ya mobile taps) ke liye hai, **keyboard** ke liye mushkil hai. (Text field overlap karne par bhi user jo type karega wo dikhega nahi, to log type karna band kar denge.)

Purani (kamzor) defences

Framebusting

```
js

if (top != window) {
  top.location = window.location;
}
```

Page khud ko top window bana leta hai. **Reliable nahi**, hack ho sakta hai:

- **beforeunload** se block: evil page `window.onbeforeunload = () => false` lagati hai. Jab `iframe` `top.location` badalne ki koshish karta hai to user se "leave karna hai?" puchha jaata hai, wo aksar "No" kehta hai, aur redirect nahi hota.
- **sandbox** attribute: evil page `iframe` ko `sandbox="allow-scripts allow-forms"` ke saath daalti hai, `allow-top-navigation` **nahi**, isliye `top.location` badalna forbidden ho jaata hai.

X-Frame-Options (server-side header)

Ye **HTTP header** hi hona chahiye (HTML `<meta>` me daalne par ignore hota hai). 3 values:

- **DENY**: kabhi kisi frame me nahi dikhega
- **SAMEORIGIN**: sirf same origin ka parent document frame me dikha sakta hai
- **ALLOW-FROM domain**: sirf diye gaye domain ka parent

Twitter `X-Frame-Options: SAMEORIGIN` use karta hai.

Side effect: dusri sites jinke paas achhi wajah ho, wo bhi hamara page frame me nahi dikha sakti.

Functionality band karke dikhana (covering <div>)

Page ko `height: 100%; width: 100%` ke ek `<div>` se **dhak do** jo saare clicks le leta hai. Ye div hatao agar `window == top` (ya protection ki zarurat nahi):

```
html

<style>
  #protector {
    height: 100%; width: 100%;
    position: absolute; left: 0; top: 0;
    z-index: 99999999;
  }
</style>
<div id="protector"><a href="/" target="_blank">Go to the site</a></div>
<script>
  // top alag origin ka ho to error aayega, par yaha theek hai
  if (top.document.domain == document.domain) {
    protector.remove();
  }
</script>
```

samesite cookie attribute

Aise cookie ko sirf tab bheja jaata hai jab site **seedhe** khuli ho, frame ya aur tarike se nahi.

```
Set-Cookie: authorization=secret; samesite
```

Agar Facebook ka auth cookie aisa hota to dusri site ke iframe me kholne par cookie na jaati aur attack fail ho jaata.

Limitation: agar cookies use hi nahi ho rahi (jaise IP address se duplicate votes rokne wala anonymous polling site), to `samesite` se madad nahi milti aur clickjacking phir bhi chal sakti hai. Saath hi public, unauthenticated pages iframe me dikhana aasan rehta hai.

Summary

- Clickjacking = user ko bina jaane victim site par click karwa dena. Khatarnak isliye ki UI design karte waqt hum ye sochte hi nahi ki koi hacker user ki taraf se click kar sakta hai.
- Jo pages frames me nahi dikhane, unpar `X-Frame-Options: SAMEORIGIN` lagao.
- Agar pages ko iframes me dikhane bhi dena ho to **covering** `<div>` use karo.
- `samesite` cookies bhi help karti hain.